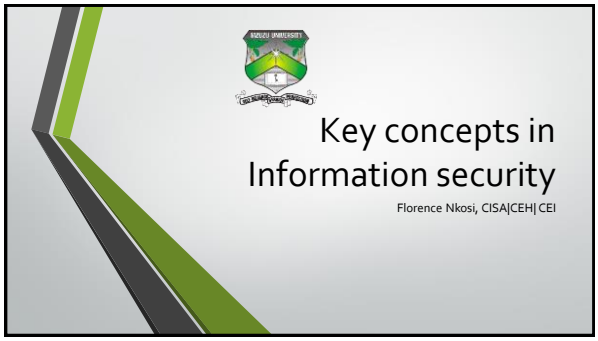


Topics Already Covered

- Principles of Security – CIA Triad, Covered in introduction
- Threats, vulnerabilities and attacks – covered
- Active and passive attacks- Covered
- Authentication, authorization and Accounting – covered
- Some countermeasures of threats and attacks – covered
- Intrusion detection and prevention systems- covered

Security Vulnerabilities

- List of websites that you may use to find vulnerabilities of various softwares
- • OWASP - (http://www.owasp.org)
- • National Vulnerability Database - (http://nvd.nist.gov)
- • SANS Top 20 - (www.sans.org/top20)

Network Security

- Network is a set of rules and configurations designed to protect the integrity, confidentiality and accessibility of computer networks and data using both software and hardware technologies.
- Today's network architecture is complex and is faced with a threat environment that is always changing and attackers that are always trying to find and exploit vulnerabilities.
- There are many layers to consider when addressing network security across an organization, as attacks can happen at any layer in the network security layers model.
- In addition to protecting assets and the integrity of data from external exploits, network security can also manage network traffic more efficiently, enhance network performance and ensure secure data sharing between employees and data sources.
- Network security typically consists of three different controls: **physical, technical and administrative.**

Network security controls

Physical Network Security

- Physical security controls are designed to prevent unauthorized personnel from gaining physical access to network components such as routers, cabling cupboards and so on. Controlled access, such as locks, biometric authentication and other devices, is essential in any organization.

Technical Network Security

- Technical security controls protect data that is stored on the network or which is in transit across, into or out of the network.
- Protection is twofold; it needs to protect data and systems from unauthorized personnel, and it also needs to protect against malicious activities from employees.

Administrative Network Security

- Administrative security controls consist of security policies and processes that control user behavior, including how users are authenticated, their level of access and also how IT staff members implement changes to the infrastructure.

FOCUS OF NETWORK SECURITY

- Within network security, there are three key focuses that should serve as a foundation of any network security strategy: protection, detection and response.
  - **Protection** entails any tools or policies designed to prevent network security intrusion.
  - ***Detection*** refers to the resources that allow you to analyze network traffic and quickly identify problems before they can do harm.
  - ***Response*** is the ability to react to identified network security threats and resolve them as quickly as possible

- **Network access controls**
- **Firewalls**
- **Security information and event Manager**

Network Access Controls(NAC)

- Access control Lists are rule-based lists that are used by switches and routers to identify traffic based on characteristics such as the IP address or port number.
- Once identified the router or switch can filter the traffic, allowing or denying access to a network

Network Access Controls(NAC)

- Network Access control allows you to increase your network security by limiting user access and resources to only the parts of the network that directly apply to individual users' responsibilities
- NAC helps to prevent unauthorized devices from being joined to your network in the first place or sending data into your network.
- ACL's are configured on a network router to allow specific traffic and deny specific traffic

Example of an Access list

rule	action	src address	dest address	protocol	dest port
1	allow	172.16.0.0/16	10.2.0.0/16	TCP	80
2	allow	10.2.0.0/16	172.16.0.0/16	TCP	> 1023
3	allow	172.16.0.0/16	10.2.0.0/16	UDP	53
4	allow	10.2.0.0/16	172.16.0.0/16	UDP	> 1023
5	deny	all	all	all	all

Network Access controls

- Network access control (NAC) can be set at the most granular level. For example, you could grant administrators full access to the network but deny access to specific confidential folders or prevent their personal devices from joining the network.
- Before giving access to the network, NAC checks the device's security settings to ensure that they meet the predefined security policy; for example, it might check whether the host has the latest antivirus software and the latest patches.
- If the conditions are met, the device is allowed to enter the network. If not, NAC will quarantine the endpoint or connect it to the guest network until the proper security enhancements are made to comply with policy.

Network Access Controls(NAC

- ACLs can be categorized by the way they identify traffic:
  - **Standard ACLs** block or allow an entire protocol suite using source IP addresses.
  - **Extended ACLs** block or allow network traffic based on a more differentiated set of characteristics that includes source and destination IP addresses and port numbers, as opposed to just source address.

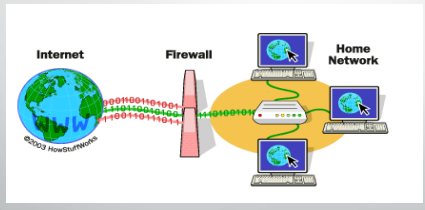
Benefits of ACL

- **Simplified user identification.** An access control list simplifies the way that users are identified. ACLs ensure that only approved users and traffic have access to a system.
- **Performance.** ACLs are configured directly on the routing device's forwarding hardware, so access control lists do not have a negative performance effect on routing devices.
- **Control.** ACLs can give administrators more granular control over user and traffic permissions on a network at many different points in the network. They help control access to network endpoints and traffic flowing between internal networks.

Firewalls

- Firewalls put up a barrier between a trusted internal network and untrusted outside networks, such as the Internet.
- Also defined as any perimeter device that permits or denies traffic based on a set of rules configured by the administrator.
- The firewall is the barrier between a **trusted and untrusted network**, often used between your LAN and WAN.
- They use a set of defined rules to allow or block traffic
- A firewall can be hardware, software, or both.
- The firewall protects everything "behind" it from everything in "front" of it. Usually the "front" of the firewall is its Internet facing side, and the "behind" is the internal network.

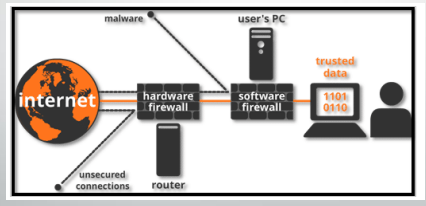
Firewall



Firewalls

- A network firewall is based on security rules to **accept**, **reject**, or **drop** specific traffic.
- The aim of the firewall is to allow or deny the connection or request, depending on implemented rules.
- There 3 types of firewalls: hardware firewall, Software firewall and both
  - **Hardware firewalls**: hardware firewalls are security devices that represent a separate piece of hardware placed between an internal and external network (the Internet). They are standalone products. These are also found in broadband routers.
  - **Software firewalls** are installed on your computers. A software firewall protects your computer from internet threats i.e Windows Defender Firewall
  - **Both**: Combination of both Hardware and software

Firewalls



How a firewall works

- The main function of a firewall is to block any unauthorized access attempt to private internal devices of our data network (LAN) from the external internet connections commonly called WAN.
- It provides a way to filter the information that is communicated through the network connection.
- It allows or blocks the communication between clients within the network based on rules.
- Each rule defines a certain network traffic pattern and action to perform when detected.
- These customizable rules provide control and fluency over the use of the network.
- If traffic complies with the configured rules in firewalls, traffic can enter or leave our network. If not, then the traffic will be blocked and cannot reach its destination.

How a firewall works

- A firewall system analyzes network traffic based on pre-defined rules.
- It then filters the traffic and prevents any such traffic coming from unreliable or suspicious sources. It only allows incoming traffic that is configured to accept.
- Typically, firewalls intercept network traffic at a computer's entry point, known as a port. Firewalls perform this task by allowing or blocking specific data packets (units of communication transferred over a digital network) based on pre-defined security rules. Incoming traffic is allowed only through trusted IP addresses, or sources.

Rules that Can be Implemented in Firewall

- The type of rules and functionalities that can be built in it are the following:
  - Manage user access to private network services such as server applications.
  - Record all attempts to enter and exit a network. Entry and exit attempts are stored in logs.
  - Control the number of connections that are occurring from the same point and block them if they exceed a certain limit. In this way, it is possible to avoid some denial of service attacks.
  - Control applications that may access the Internet. Thus, we can restrict access to certain applications, such as dropbox, to a certain group of users.
  - Detection of ports that are listening and in principle should not be. Thus, the firewall can warn us that an application wants to use a port to wait for incoming connections.

Rules that can be implemented on a firewall

- There are specific access control policies or rules set by the administrator that governs what data packet is allowed and what is not. These rules are known as the access control list.
- This list may contain allowed and denied port numbers, internet protocol used by the request, and IP addresses.
- This list is customizable and the network administrator can, not only prevent what can enter the network but also what leaves a network

Permit	IP Address	Internet Protocol	Destination	Port
Allowed	164.212.214.140	TCP	Any	70
Allowed	55.20.60.40	TCP	Any	70
Allowed	40.50.10.100	TCP	Any	70
Denied	45.20.10.10	TCP	Any	70

Types of firewall techniques

- Depending on their structure and functionality, there are different types of firewalls
- These are categorized as follows:
  - Packet-filtering
  - Stateful Packet Inspection
  - Circuit level gateway
  - Next generation firewall

Packet Filtering firewall

- These firewalls are designed to block network traffic IP protocols, an IP address, and a port number if a data packet does not match the established rule-set.
- It has filters that compare incoming and outgoing packets against a standard set of rules to decide whether to allow them to pass through.
- A packet-filtering firewall is a primary and simple type of network security firewall.
  - It monitors network traffic by filtering incoming packets according to the information they carry.
  - Decides whether a packet is allowed or denied access based on the header information (protocol, source IP address, destination IP, source port, and destination port)
  - Depending on how the numbers match the **access control list** (rules defining wanted/unwanted traffic), the packets are passed on or dropped.

Packet-filtering Firewall

- A packet-filtering firewall is a fast solution that doesn't require a lot of resources. However, it isn't the safest.
- Although it inspects the header information, it doesn't check the data (payload) itself.
- Because malware can also be found in this section of the data packet, the packet-filtering firewall is not the best option for strong system security.

Stateful Inspection Firewalls

- A Stateful inspection firewall keeps track of the state of a connection by monitoring the TCP 3-way handshake.
- This allows it to keep track of the entire connection – from start to end – permitting only expected return traffic inbound.
- When starting a connection and requesting data, the stateful inspection builds a database (state table) and stores the connection information. In the state table, it notes the source IP, source port, destination IP, and destination port for each connection.
- Using the stateful inspection method, it dynamically creates firewall rules to allow anticipated traffic.
- This type of firewall is used as additional security. It enforces more checks and is safer compared to stateless filters.
- However, unlike stateless/packet filtering, stateful firewalls inspect the actual data transmitted across multiple packets instead of just the headers. Because of this, they also require more system resources.

Stateful Inspection Firewall

- Using the stateful inspection method, it dynamically creates firewall rules to allow anticipated traffic.
- This type of firewall is used as additional security. It enforces more checks and is safer compared to stateless filters.
- However, unlike stateless/packet filtering, stateful firewalls inspect the actual data transmitted across multiple packets instead of just the headers. Because of this, they also require more system resources.

Circuit-Level Gateways firewall

- Circuit-level gateways are another simplified type of firewall that can be easily configured to allow or block traffic without consuming significant computing resources.
- These types of firewalls typically operate at the session-level of the OSI model by verifying TCP (Transmission Control Protocol) connections and sessions.
- Circuit-level gateways are designed to ensure that the established sessions are protected.
- Typically, circuit-level firewalls are implemented as security software or pre-existing firewalls.

Circuit-Level Gateways firewall

- Like packet-filtering firewalls, these firewalls do not check for actual data, although they inspect information about transactions. Therefore, if a data contains malware, but follows the correct TCP connection, it will pass through the gateway.
- That is why circuit-level gateways are not considered safe enough to protect our systems.
- Additionally, circuit-level gateways are practical, simple to set up, and don't require a separate proxy server.

Next-Generation Firewalls (NGFW)

- The next-generation firewall is a security device that combines a number of functions of other firewalls.
- It incorporates packet, stateful, and deep packet inspection.
- Simply put, NGFW checks the actual payload of the packet instead of focusing solely on header information.
- Unlike traditional firewalls, the next-gen firewall inspects the entire transaction of data, including the TCP handshakes, surface-level, and deep packet inspection.
- Using NGFW is adequate protection from malware attacks, external threats, and intrusion.
- These devices are quite flexible, and there is no clear-cut definition of the functionalities they offer. Therefore, make sure to explore what each specific option provides.

Next Generation Firewall (NGFW's)

- NGFWs build upon traditional firewalls' features and add other critical security functions like intrusion prevention, VPN, anti-malware, and even encrypted traffic inspection.
  - NGFW's ability to handle deep packet inspection means that the firewall can unpack the packet's data to prevent any packets with malicious data from moving forward.
  - Free Firewalls: Comondo firewall, Glasswire, AVS firewall



- Types of firewalls
  - Hardware
  - Software
  - Both(hardware and software)

- **Types** of firewall **techniques**
  - Packet-filtering
  - Stateful Packet Inspection
  - Circuit level gateway
  - Next generation firewall

Firewall role in network security

- A firewall plays a vital role in network security and is designed to address the issues of data integrity and confidentiality of internal network.
- The importance of including a firewall in security strategy is consequent;
- The role of a Firewall in network security is to ensure network security by inhibiting the external threats coming from potent sources such as hackers and avoid any kind of connection between the two.
- Firewalls also guards the internal infrastructure of the network by occluding the viruses and malware.

Limitations of Firewalls

- Firewalls do have following limitations:
  - A firewall can't prevent the users or attackers with modems from dialing in to or out of the internal network.
  - Firewalls cannot enforce the password policy or prevent misuse of the password.
  - Firewalls cannot stop internal users from accessing websites with malicious program code and software's that might install viruses.
  - Firewalls can't protect from poor decisions.

Factors to consider when choosing a firewall

The size of the organization.

How big is the internal network? Can you manage a firewall on each device, or do you need a firewall that monitors the internal network?. Additionally, the decision between the two will largely depend on the capabilities of the tech team assigned to manage the setup.

The resources available

Can you afford to separate the firewall from the internal network by placing it on a separate piece of hardware or even on the cloud? The traffic load the firewall needs to filter and whether it is going to be consistent also plays an important role.

The level of protection required.

The number and types of firewalls should reflect the security measures the internal network requires. A business dealing with sensitive client information should ensure that data is protected from hackers by tightening the firewall protection.

Unified threat management (UTM)

- Unified threat management (UTM) is an approach to information security in which a single hardware or software installation provides multiple security functions (intrusion prevention, antivirus, content filtering and so forth).
- This contrasts with the traditional method of having point solutions for each security function.
- UTM simplifies information-security management because the security administrator has a single management and reporting point.
- UTM security appliances unify and integrate multiple security features onto a single hardware platform, including network firewall capabilities, network intrusion detection and prevention, and gateway anti-virus.
- UTM appliances have quickly gained popularity, partly because of the all-in-one approach simplifies installation, configuration and maintenance. Such a setup saves time, money and people when compared to the management of multiple security systems.

Unified threat management (UTM)

- A UTM system does not just protect personal computers (PCs) and servers. It protects an entire network and individual users by scanning all network traffic, filtering potentially dangerous content and blocking intrusions
- A UTM appliance will usually include functions such as: antivirus, anti-spyware, anti-spam, network firewalling, intrusion detection and prevention, content filtering and leak prevention. Some units also provide services such as remote routing, network address translation (NAT), and virtual private network (VPN) support.

FEATURES OF UTM SOLUTIONS

- Almost every unified threat management application includes the same seven features.
- Some applications may also include additional features in order to appeal to certain customers.
  - Antivirus
  - Antimalware
  - Firewall
  - Intrusion prevention
  - Virtual private networking (VPN)
  - Web filtering
  - Data loss prevention

Examples of UTM: Fortinet UTM, untangle NG firewall , Sophos XG firewall.

Benefits of UTM

- UTM solutions also help to protect networks against combined threats.
- These threats consist of different types of malware and attacks that target separate parts of the network simultaneously. When using separate appliances for each security wall, preventing these combined attacks can be difficult.
- Because it is a single point of defense, UTM's make dealing with combined threats easier.
- A UTM
  - Secures the network from viruses, malware, or malicious attachments by scanning the incoming data using Deep Packet Inspection.
  - Prevents attacks before they enter the network by inspecting the packet headers.
  - Prevents access to unwanted websites by installing enhanced web filtering.
  - Provides ability to update automatically with the latest security updates, anti-virus definitions, and new features so that minimal manual intervention is required beyond initial set-up.
  - Enables administrators to manage a wide range of security functions with a single management console.

NGFW VS UTM

UTM vs NGFW

- UTM and next-generation firewalls (NGFWs) are both firewall technologies serving similar purposes, but they're also different in some key areas.
- NGFWs were originally developed to fill network security gaps left by traditional firewalls and include application intelligence and an intrusion prevention system (IPS), as well as DoS protection.
- UTM refers to the ability of a single device to perform the functions of an NGFW, firewall and virtual private network (VPN), while an NGFW is a network security platform that provides a gateway between internal and external networks.
- The major difference between these two firewall types is that a UTM system typically offers more features than an NGFW, such as an intrusion detection system (IDS) and spam filtering, since it is able to monitor and protect internal networks from intruders

Proxy Server

- A proxy server is a computer or an application program that intercepts user requests from the internal secure network and then processes that request on behalf of the user.
- A proxy server provides a gateway between users and the internet. It is a server, referred to as an "intermediary" because it goes between end-users and the web pages they visit online.
- Proxies communicate with websites on your behalf.



Benefits of a proxy server

- Proxies come with several benefits that can give your business an advantage:
  - **Enhanced security:** Can act like a firewall between your system and the internet. Without them, hackers have easy access to your IP address, which they can use to infiltrate your computer or network.
  - **Private browsing, watching, listening, and shopping:** Use different proxies to help you avoid getting inundated with unwanted ads or the collection of IP-specific data.
  - **Access to location-specific content**: You can designate a proxy server with an address associated with another country. You can, in effect, make it look like you are in that country and gain full access to all the content computers in that country are allowed to interact with.
  - **Prevent employees from browsing inappropriate or distracting sites:** You can use it to block access to websites that run contrary to your organization's principles. Also, you can block sites that typically end up distracting employees from important tasks. Some organizations block social media sites like Facebook and others to remove time-wasting temptations.

Types of Proxy Servers

- There are numerous types of proxies that you can use depending on your needs and privacy requirements. These can be generally split into three:
  - **Transparent Proxies:** As the name suggests, these proxies do not hide your real IP address, providing no additional levels of security or privacy. Transparent proxies are mostly used for content filtering purpose, rather than anonymity, such as in schools or offices.
  - **Anonymous Proxies:** If you use an anonymous proxy, the proxy will provide a fake IP address instead of your real one. Sites will still be able to determine whether you are using a proxy server, they just will not be able to determine your real IP address. Some sites, however, have begun to block traffic from proxy servers.
  - **High Anonymity Proxies:** All the anonymity of an anonymous proxy, with the additional privacy or hiding the fact that you are using a proxy altogether. **TOR network** is an example of a high anonymity proxy server. A high anonymity server has an advantage over the anonymous proxy in terms of privacy and security.

Proxy Servers

- Some popular proxy software's:
  - Owasp Zed Attack Proxy (ZAP)
  - CCProxy
  - Forti Proxy

Differences between a Proxy and a VPN

The Main differences between a VPN and a Proxy

- VPNs encrypt your traffic while proxy servers don't. A VPN service protects you from ISP tracking, government surveillance, and hackers. Proxies don't, so they should never be used to handle sensitive information;
- VPNs work on the operating system level and reroute all your traffic while proxies work on the application level and only reroute the traffic of a specific app or browser;
- VPNs can be slower than proxies as they need to encrypt your data; however, there are ways you can improve your connection and browsing speeds;
- VPNs are usually paid (you shouldn't trust free VPN services as they have limitations and tend to mine your data) while many proxy servers are free;
- A VPN connection is more reliable while proxy server connections drop more frequently

Antivirus and Anti-malware

- Antivirus software is a class of program designed to prevent, detect and remove malware infections on individual computing devices, networks and IT systems.
- Antivirus is a kind of software used to prevent, scan, detect and delete viruses from a computer.
- Antivirus programs and computer protection software are designed to evaluate data such as web pages, files, software and applications to help find and eradicate malware as quickly as possible.
- The effectiveness of an antivirus program is heavily dependent on how often it is updated. Therefore, it is important to have the antivirus program scheduled to update daily.

How antivirus software works

- Antivirus software usually performs these basic functions:
  - Scanning directories or specific files for known malicious patterns indicating the presence of malicious software;
  - Allowing users to schedule scans so they run automatically;
  - Allowing users to initiate new scans at any time; and
  - Removing any malicious software it detects. Some antivirus software programs do this automatically in the background, while others notify users of infections and ask them if they want to clean the files.

Virus detection techniques

- It recognizes malware in different ways;
  - **Signature based recognition** compares the scanned content against a list of known viruses. This requires constant updating of the list of 'fingerprints' of known viruses.
  - Stored virus signatures -- unique strings of data that are characteristic of known malware
    - Viruses not on the list yet will be missed.
    - Also variations of the same virus may be missed if the characteristic fingerprint is changed or masked.
  - **Using heuristics**: Instead of relying on malware that has been seen in the wild, as signatures do, heuristics tries to identify previously unseen malware.
    - Heuristics detection will scan the file for features frequently seen in malware, such as attempts to access the boot sector, write to an EXE file or delete hard-drive contents.

Email security

- Email security is the process of ensuring the availability, integrity and authenticity of email communications by protecting against the risk of email threats.
- Email is an especially important factor to consider when implementing networking security tools.
- There are numerous email threats such as scams, phishing, malware, and suspicious links, can be attached to or incorporated into emails.
- Because so many of these threats will often use elements of personal information in order to appear more convincing, it is important to ensure an organization's employees undergo sufficient security awareness training to detect when an email is suspicious.

Email security

- Email security tools can block both incoming attacks and outbound messages with sensitive data
- Numerous threat vectors, like scams, phishing, malware, and suspicious links, can be attached to or incorporated into emails.
- Phishing allows intruders to gain access to the network. Email security blocks phishing emails and outbound messages carrying sensitive data, flags emails that have suspicious links and files.
- Email security on a network is achieved by implementing tools such as security gateway for email servers. An Email Security Gateway, a platform which guards your emails against hackers, spam and viruses by using the latest email threat detection technology and policy enforcement tools to keep good emails flowing to and from your users.
- Examples of Email Security Software's: ***Mimecast Email Security, Spambrella, Secure mail gateway and proof point essentials..***

Routers

- A router is a switching device for networks, which is able to route network packets, based on their addresses, to other networks or devices.
- Routers are not only the foundation of the Internet; they are the foundation of how your company communicates both externally and internally.
- Among other things, they are used for Internet access, for coupling networks or for connecting branch offices to a central office via VPN (Virtual Private Network).
- Most CISCO routers comes with a firewall, in this case the router acts as a barrier between the Internet and devices on your home network.
- Routers provide one of the most fundamental functions on a network and are often installed and run with out-of-the-box security.

How Routers work

1. Used to used to transfer data packets between networks.
2. Routers can also provide security. Embedded firewall and content filtering software provide an additional protection from unwanted content and malicious websites without affecting your online experience.
3. Most routers allow you to connect hard drives and use them as file-sharing servers, or printers that can then be accessed by anyone on the network.

Various types of Routers

- Broadband Routers
- Core Routers
- Wireless routers
- Virtual router

Various types of Routers

1. **Broadband Routers**
   - Broadband routers are built for ease of installing home networks, especially for households with high-speed Internet service. In addition to allowing all consumer appliances devices to share an internet connection, broadband routers often allow data, printers as well as other electronic devices to be shared between home computers and other devices.
2. **Wireless Routers**
   - A wireless router is also known as a WLAN (wireless local area network) device. This wireless Network established is termed a Wi-Fi network. Wireless routers are used in homes. that Internet service providers (ISP) use routers to connect to xDSL or network Internet cable. Wi-Fi router integrates a wireless access point's networking functions with a router

Various types of Routers

3. Core Router

- A core router is a computer communication device and a backbone of the network, which means it links all network devices. It allows for fast data communication.
- It is a wired or wireless router that distributes data packets within a network but does not distribute data packets within multiple networks.

4. Virtual Router

- Virtual routers provide Computer sharing network by default. Virtual routers provide multitenant network services for private, public, as well as provider-hosted clouds. It works as per the redundancy protocol for the virtual router (VRRP), it becomes active when the main or primary router is disabled. It takes a group of multiple routers to share a virtual IP address. In this, each group has a master that handles IP packets. If packets from the master fail to forward, then other routers take a position.

Various types of Routers

- 5. Edge router
- An edge router, also called a gateway router or just "gateway" for short, is a network's outermost point of connection with external networks, including the Internet.

Security information and event management (SIEM)

- Security information and event management (SIEM) is an approach to security management that combines SIM (security information management) and SEM (security event management) functions into one security management system
- SIEM works by combining two technologies: a) Security information management (SIM), which collects data from log files for analysis and reports on security threats and events, and b) security event management (SEM), which conducts real-time system monitoring, notifies network admins about important issues and establishes correlations between security events.
- The underlying principles of every SIEM system is to aggregate relevant data from multiple sources, identify deviations from the norm and take appropriate action.
- For example, when a potential issue is detected, a SIEM system might log additional information, generate an alert and instruct other security controls to stop an activity's progress.
- At the most basic level, a SIEM system can be rules-based or employ a statistical correlation engine to establish relationships between event log entries.
- Advanced SIEM systems have evolved to include user and entity behavior analytics (UEBA) and security orchestration, automation and response (SOAR).

Security information and event management (SIEM)

- SIEM systems work by deploying multiple collection agents in a hierarchical manner to gather security-related events from end-user devices, servers and network equipment, as well as specialized security equipment, such as firewalls, antivirus or intrusion prevention systems (IPSes).
- The collectors forward events to a centralized management console, where security analysts sift through the noise, connecting the dots and prioritizing security incidents.

How does SIEM work?

- SIEM tools work by gathering event and log data created by host systems, applications and security devices, such as antivirus filters and firewalls, throughout a company's infrastructure and bringing that data together on a centralized platform.
- The SIEM tools identify and sort the data into such categories as successful and failed logins, malware activity and other likely malicious activity.
- The SIEM software then generates security alerts when it identifies potential security issues. Using a set of predefined rules, organizations can set these alerts as low or high priority.
- For instance, a user account that generates 25 failed login attempts in 25 minutes could be flagged as suspicious but still be set at a lower priority because the login attempts were probably made by the user who had probably forgotten his login information.
- However, a user account that generates 130 failed login attempts in five minutes would be flagged as a high-priority event because it's most likely a brute-force attack in progress.

SIEM tools and software

- Splunk
- IBM QRADAR
- EXABEAM
- Archsight

Why is SIEM Important?

- SIEM is important because it makes it easier for enterprises to manage security by filtering massive amounts of security data and prioritizing the security alerts the software generates.
- SIEM software enables organizations to detect incidents that may otherwise go undetected. The software analyzes the log entries to identify signs of malicious activity.

DESIGNING A COMPHREHENSIVE NETWORK SECURITY PLAN

- A widely accepted method for developing your network security plan is laid out in Request for Comments (RFC) 2196
- It consists of the following steps:
  - Identify what you are trying to protect. (servers,computers,cables)
  - Determine what you are trying to protect it from (brute force attacks,denial of service etc)
  - Determine how likely the anticipated threats are.
  - Implement measures that will protect your assets in a cost-effective manner (firewall,antivirus,SIEM, NGFW,UTM)
  - Review the process continually and make improvements each time a weakness is discovered.

DESIGNING A COMPHREHENSIVE NETWORK SECURITY PLAN

- Network security is essentially the power to protect your business and your customers.
- That means understanding the threats and the solutions and knowing how to use that information to build a robust and inclusive network security strategy.
- Network security is best achieved through a combination of hardware and software. In an ideal security environment, all of the components work together to minimize maintenance and improve security.

"The only truly secure system is one that is powered off, cast in a block of concrete and sealed in a lead-lined room with armed guards."

E. Spafford